

AUREUM CAP V0.1 — Next-Phase TODO

Twilio integration, blocker removal, and controlled path to 100% production readiness

Document status: Active execution checklist

Created: 22 September 2026

Repository: osasbenny/AUREUM-CAP-V0.1

Current safe state: CAP_SEND_ENABLED=false ; CAP_SMS_SEND_ENABLED=false

Immediate objective: Move from infrastructure verification to a compliant, observable, review-first SMS pilot without bypassing recipient eligibility or provider restrictions.

1. Operating decision

The next phase must not begin by enabling a 50-recipient send. The authoritative 100-lead report currently records **100 imported, unique records; 100 phone numbers; 0 verified emails; and 0 outreach-eligible records**. Every record lacks a documented recipient identity, lawful-contact basis, suppression result, or channel-specific permission evidence.

The implementation target is therefore a **compliance-qualified 5–10-recipient pilot**. The existing 50-recipient manifest remains a preparation artifact only. It cannot be activated until every selected record has recipient-level eligibility evidence, suppression clearance, exact-message approval, and a bounded sending configuration.

Any Twilio credentials previously pasted into chat are treated as compromised. They must be revoked or rotated and must not be reused.

2. Definition of 100% completion

CAP V0.1 reaches 100% production readiness when all of the following are true:

- The public Command Center, API, HTTPS load balancer, ECS service, RDS database, SQS queues, object storage, and logging are verified in production.
- The authoritative lead records are persisted in RDS, deduplicated, and reconciled with the readiness report.
- Every eligible recipient has a verified channel, recipient identity, lawful-contact basis, source evidence, suppression result, and audit history.
- Twilio credentials are fresh, server-side, secret-managed, and never exposed to the browser, Git, or chat.

- A compliant U.S. sender or Messaging Service is configured and its applicable registration is approved.
- Status callbacks and inbound messages reach the production API, pass signature validation, and persist events in RDS.
- STOP, UNSUBSCRIBE, CANCEL, QUIT, END, and REVOKE messages suppress future outbound contact.
- The SQS worker is durable, idempotent, rate-limited, retry-safe, and DLQ-observable.
- The Command Center shows recipient, message, sender, provider, permission evidence, suppression result, approval history, and batch limits before a send can be enabled.
- An operator-owned test number has completed a provider-connected dry run and a real test delivery.
- The exact pilot payload is approved before transmission, with a stop control and rollback procedure tested.
- Delivery, failure, opt-out, reply, proposal, deal, purchase, and attributable revenue events are persisted and visible.
- Email remains separately gated until its sender, domain, delivery events, unsubscribe handling, and lawful basis are complete.

3. Phase 0 — Protect credentials and freeze activation

Tasks

- ☐ Revoke or rotate every Twilio Auth Token and API key that was exposed in chat or any non-secret location.
- ☐ Create fresh Twilio credentials through the Twilio Console.
- ☐ Store the fresh credentials in AWS Secrets Manager or the approved ECS secret-injection path.
- ☐ Confirm that no Twilio secret appears in Git history, `.env` files, Vercel client variables, browser payloads, logs, screenshots, or reports.
- ☐ Keep `CAP_SEND_ENABLED=false` and `CAP_SMS_SEND_ENABLED=false` throughout configuration and testing.
- ☐ Add a deployment check that fails closed when required secrets, sender configuration, or compliance flags are missing.
- ☐ Record the credential rotation date and secret ARN/identifier, but never record the secret value.

Exit criteria

The old credentials are unusable, fresh credentials are secret-managed, the browser cannot read them, and both live-send gates remain disabled.

4. Phase 1 — Verify production infrastructure and data persistence

API and frontend

- ☐ Verify `https://api.cactusdigitalmedia.ng/health` returns HTTP 200 with the expected service identity and disabled-send state.
- ☐ Verify `/readiness` reports the true status of database, storage, queue, provider, sender, webhooks, suppression, and send gates.
- ☐ Verify the Vercel production build uses the correct `VITE_API_BASE_URL` and does not contain provider credentials.
- ☐ Test Command Center login with a non-development production admin identity.
- ☐ Test lead search, selection, select-all, individual verification, bulk verification, approval, refresh, logout, campaign view, and revenue view.
- ☐ Confirm that every action shows loading, success, and actionable error states.
- ☐ Confirm that approval state persists after refresh and after an ECS restart.

AWS and RDS

- ☐ Verify the HTTPS certificate, DNS route, ALB target health, ECS desired/running count, and CloudWatch application logs.
- ☐ Execute `db/apply-schema.sh` from a VPC-connected runner using the managed database secret.
- ☐ Execute `db/verify-schema.sql` against private RDS.
- ☐ Confirm the expected tables, indexes, constraints, audit events, suppression records, provider events, and queue job records exist.
- ☐ Import the authoritative 100-lead manifest into RDS using an idempotent transaction.
- ☐ Reconcile the database count with the report: 100 source records, 100 unique records, and no duplicate lead keys.
- ☐ Confirm the API reads leads and dashboard metrics from PostgreSQL rather than process memory.

- ☐ Confirm SQS processing and dead-letter queues are configured with appropriate visibility timeout, retry count, and retention.
- ☐ Confirm worker logs include job ID, lead ID, provider, outcome, retry count, and correlation ID without secret values.

Exit criteria

The API and Command Center are connected to production, RDS contains the authoritative lead set, persistence survives restart, and infrastructure health is evidenced in logs and verification output.

5. Phase 2 — Qualify the lead data and lawful-contact basis

Per-lead qualification fields

For each of the 100 leads, persist:

- Business identity and source document reference.
- Phone number, normalization result, and country.
- Named recipient, role, and identity-confidence evidence.
- Website and independent verification result.
- Contact-source URL or document and collection date.
- Channel-specific permission or lawful basis.
- Suppression and opt-out lookup result with timestamp.
- Research confidence, business-fit hypothesis, and evidence limitations.
- Proposed offer and exact message version.
- Approval state, approving operator, approval timestamp, and audit event.

Tasks

- ☐ Separate a phone number from a verified business contact or decision-maker identity.
- ☐ Perform an authoritative suppression lookup before any recipient can enter an eligible state.
- ☐ Document the applicable U.S. SMS compliance basis for each selected recipient with legal review where required.

- ☐ Mark all records without sufficient evidence as blocked rather than inferring consent from public availability.
- ☐ Preserve the distinction between a provisional product-fit hypothesis and verified customer need.
- ☐ Select no more than 5–10 pilot recipients using transparent criteria after eligibility evidence exists.
- ☐ Keep the remaining records in research, compliance review, not-fit, or suppressed states.

Exit criteria

The selected pilot contains only records with recipient-level evidence. Records without evidence remain blocked, and the database and Command Center show the reason for every block.

6. Phase 3 — Integrate Twilio server-side

Provider adapter

- ☐ Implement a single server-side Twilio adapter using the official Messages API or a configured Messaging Service.
- ☐ Accept only server-side secret references; reject requests that attempt to supply credentials from the browser.
- ☐ Require an approved sender or Messaging Service SID before constructing a live request.
- ☐ Normalize recipients to E.164 and reject malformed or unsupported destinations.
- ☐ Generate an idempotency key from campaign, lead, message version, and recipient so retries cannot duplicate a message.
- ☐ Apply per-run, per-minute, and per-day limits from persisted campaign configuration.
- ☐ Persist an outbound-attempt record before provider submission.
- ☐ Persist the provider message SID, request timestamp, response status, and normalized error after submission.
- ☐ Treat provider acceptance as `queued`, not `delivered`.
- ☐ Never report success to an operator until the provider response is persisted.

Secret and configuration contract

Store the following as server-side configuration or secret references:

Configuration	Storage requirement
Twilio Account SID or API key SID	Secret-managed runtime configuration
Twilio Auth Token or API key secret	AWS Secrets Manager; never client-side
Approved phone number or Messaging Service SID	Server-side non-secret configuration after verification
Status callback URL	Production HTTPS configuration
Inbound webhook URL	Production HTTPS configuration
Per-run and per-day limits	Persisted campaign configuration
Compliance and registration status	Persisted provider-readiness record

Exit criteria

A provider-connected dry run can construct a request and persist an idempotency record without contacting a lead. A live provider call is possible only for an operator-owned test number after all safety checks pass.

7. Phase 4 — Complete U.S. sender and compliance setup

- ☐ Verify that the supplied sender is SMS-capable and owned by the project account.
- ☐ Decide whether the pilot uses a toll-free sender, a local 10DLC number, or a Messaging Service.
- ☐ Complete the applicable Twilio registration and verification process for the chosen sender.
- ☐ Record the registration status, campaign use case, message flow, opt-out language, and expected volume.
- ☐ Confirm that the sender is permitted to reach the intended U.S. destinations.
- ☐ Configure the public privacy/terms and contact path required by the selected messaging program.

- ☐ Confirm that the message contains a clear sender identity and an opt-out path appropriate to the approved program.
- ☐ Do not treat account creation as sender approval or registration completion.

Exit criteria

Twilio and the applicable U.S. registry show the sender as approved for the intended use case, and the status is recorded in the CAP provider-readiness table.

8. Phase 5 — Configure callbacks, suppression, and replies

Status callback

- ☐ Configure Twilio status callbacks to `https://api.cactusdigitalmedia.ng/api/v1/webhooks/sms/status`.
- ☐ Validate Twilio signatures using the production Auth Token without logging the token.
- ☐ Reject malformed, unsigned, replayed, or mismatched webhook requests.
- ☐ Persist `queued`, `accepted`, `sending`, `sent`, `delivered`, `undelivered`, `failed`, and provider-error events.
- ☐ Make callback handling idempotent by provider message SID and event timestamp.
- ☐ Reconcile callbacks with outbound attempts and lead/campaign records.

Inbound reply and opt-out handling

- ☐ Configure the inbound webhook at `https://api.cactusdigitalmedia.ng/api/v1/webhooks/sms/inbound`.
- ☐ Persist inbound message body, sender, recipient, provider SID, timestamp, and matched lead.
- ☐ Detect `STOP`, `UNSUBSCRIBE`, `CANCEL`, `QUIT`, `END`, and `REVOKE` case-insensitively.
- ☐ Create an immediate suppression record and block future outbound jobs for the number.
- ☐ Return the configured provider response without exposing internal details.
- ☐ Route non-opt-out replies to the operator inbox or Command Center reply queue.
- ☐ Record response classification, human handoff, proposal, deal, purchase, and attributable revenue events without fabricating outcomes.

Exit criteria

A test callback and inbound test message are signature-validated, persisted, visible in the Command Center, and idempotent. A test STOP immediately blocks future sends.

9. Phase 6 — Durable SQS worker and stop controls

- ☐ Make the worker consume only approved, eligible, unsuppressed SMS jobs.
- ☐ Recheck eligibility, suppression, approval, provider readiness, and campaign limits immediately before sending.
- ☐ Use visibility timeout and bounded retries for transient provider failures.
- ☐ Move exhausted jobs to the DLQ with a human-readable reason and correlation ID.
- ☐ Delete an SQS message only after the durable outcome is recorded.
- ☐ Prevent duplicate sends across worker restart, timeout, and callback replay.
- ☐ Add a global kill switch and campaign-level pause switch that workers check before every provider call.
- ☐ Pause the campaign automatically on abnormal failure rate, duplicate detection, unexpected opt-outs, or compliance mismatch.
- ☐ Reconcile queue state, RDS status, provider status, and Command Center metrics.

Exit criteria

A restart-safe dry run proves idempotency, retry, DLQ, pause, and kill-switch behavior without sending to a real prospect.

10. Phase 7 — Command Center completion

The send-preview screen must display the exact recipient, channel, message, sender, provider, lawful-contact evidence, suppression result, approval history, batch size, rate limit, and stop controls.

- ☐ Add a provider-readiness panel showing sender, registration, secret presence, callback health, and last test time.
- ☐ Add lead-level compliance evidence and suppression history.
- ☐ Add a review-only message preview with immutable message versioning.
- ☐ Add separate SMS and email gates.

- ☐ Add a dry-run control that cannot contact a real lead.
- ☐ Add an exact-batch approval action that records operator identity, timestamp, payload hash, and expiration.
- ☐ Require reapproval when recipient, message, sender, provider, or batch size changes.
- ☐ Add visible pause and emergency-stop controls.
- ☐ Show provider status transitions and inbound replies.
- ☐ Add revenue-stage fields for response, qualified conversation, proposal, deal, purchase, and attributable amount.

Exit criteria

The operator can inspect and approve a bounded payload, see all evidence before sending, pause the campaign, and reconcile outcomes without accessing raw secrets.

11. Phase 8 — Email remains separately blocked until complete

SMS activation must not be used to bypass unresolved email requirements. Before enabling email:

- ☐ Verify the SES domain or sender identity.
- ☐ Confirm SPF, DKIM, and DMARC records.
- ☐ Confirm SES production access or document the sandbox limit.
- ☐ Configure bounce, complaint, delivery, and unsubscribe events.
- ☐ Store SMTP/API credentials in Secrets Manager.
- ☐ Implement email suppression, idempotency, rate limits, and audit records.
- ☐ Verify the reply mailbox and sender display identity.
- ☐ Establish a lawful basis for each email recipient.

Until these tasks pass, `CAP_SEND_ENABLED` remains `false` for email.

12. Phase 9 — Test sequence and controlled activation

The activation sequence is mandatory:

1. Run static checks, API health checks, readiness checks, database verification, and frontend production checks.
2. Run a no-send queue dry run for the exact proposed pilot.

3. Run a provider-connected request-construction test with no real lead delivery.
4. Send one real test message only to an operator-owned test number after sender and callback prerequisites pass.
5. Verify the test message status callback, inbound reply, STOP suppression, audit record, and Command Center reconciliation.
6. Prepare the exact 5–10-recipient payload with recipient-level eligibility evidence.
7. Obtain explicit operator approval for that exact payload.
8. Enable only the SMS pilot gate with a conservative daily limit.
9. Send in a controlled sequence while monitoring delivery, failures, opt-outs, replies, and cost.
10. Pause immediately on any unexpected recipient, duplicate, compliance discrepancy, abnormal failure rate, or opt-out signal.
11. Reconcile every provider event to RDS and produce a pilot outcome report.
12. Expand only after the pilot meets its predefined safety and revenue-learning criteria.

13. Observability, revenue, and reporting

- ☐ Emit structured logs with correlation IDs for API request, lead, campaign, queue job, provider SID, and webhook event.
- ☐ Create CloudWatch alarms for API health, ECS task count, queue age, DLQ depth, callback failures, provider errors, and abnormal opt-outs.
- ☐ Persist cost metadata where Twilio exposes it, without inventing cost values.
- ☐ Add durable analytics for Command Center actions and pilot funnel events.
- ☐ Track sent, delivered, undelivered, failed, opted out, replied, qualified, proposed, won, purchased, and revenue-attributed states.
- ☐ Produce a post-pilot report that separates observed outcomes from assumptions and projections.
- ☐ Never mark revenue, delivery, or response as complete without a corresponding durable event.

14. Required operator inputs and approvals

The implementation cannot infer these values safely:

- Fresh Twilio credentials entered through a secure secret interface.

- Approved Twilio sender or Messaging Service.
- Applicable U.S. registration status.
- Operator-owned test number.
- Suppression source and lookup policy.
- Lawful-contact policy for each selected recipient.
- Exact 5–10-recipient pilot cohort.
- Exact approved message text and opt-out wording.
- Pilot daily limit and stop conditions.
- Approval to perform the operator-owned test delivery.
- Final approval for the exact prospect payload before live outreach.

No password, Auth Token, API key, or other secret should be entered in chat.

15. Prioritized execution order

Priority	Workstream	Release gate
0	Rotate exposed credentials and keep gates disabled	No compromised credential remains usable
1	Verify RDS schema/import and production API/frontend connection	Persistent production state is proven
2	Complete Twilio sender and applicable U.S. registration	Sender is approved for intended use
3	Configure and test webhooks, suppression, and replies	Provider events are durable and actionable
4	Harden SQS worker, idempotency, retries, DLQ, and kill switch	Worker is restart-safe and stoppable
5	Qualify recipients and record lawful-contact evidence	At least 5–10 recipients become genuinely eligible
6	Complete Command Center evidence and approval views	Exact payload can be reviewed before sending
7	Run operator-owned provider test	One controlled test is fully reconciled
8	Approve and execute the bounded pilot	Outcomes are measured and reversible
9	Complete email provider path separately	Email is not enabled by implication
10	Expand cohort only after pilot review	Scale follows evidence, not assumptions

16. Current blockers at document creation

Blocker	Current state	Required resolution
Twilio credentials	Previously exposed in chat	Revoke/rotate and secret-manage fresh credentials
Twilio sender	Supplied by operator, not independently verified	Verify SMS capability and approved use
U.S. registration	Not evidenced	Complete applicable toll-free or 10DLC process
Provider readiness	Public API reports <code>sms_provider=false</code>	Configure and verify provider readiness
SMS send gate	<code>CAP_SMS_SEND_ENABLED=false</code>	Keep disabled until every gate passes
Recipient eligibility	0 of 100 eligible	Establish identity, lawful basis, and suppression evidence
Pilot approval	Pending	Approve an exact 5–10-recipient payload only after qualification
RDS direct verification	Not evidenced in the latest pass	Run schema and import verification from a VPC-connected runner
Callback delivery	Code routes exist; production delivery unverified	Configure Twilio and run signed callback tests
Suppression	Code handling exists; source lookup incomplete	Query authoritative suppression list before queueing
Worker controls	Code-side worker exists; production reconciliation incomplete	Prove retries, idempotency, DLQ, pause, and kill switch

Blocker	Current state	Required resolution
Email	Sender/domain and delivery controls incomplete	Finish separately; do not use SMS as a bypass
Analytics	Client/event contracts exist; durable production reporting incomplete	Configure collector and revenue-event persistence
Revenue tracking	No verified responses, proposals, deals, or purchases	Capture only observed events after activation

17. Savepoint and documentation requirements

At each completed workstream, commit:

- The implementation change.
- A redacted verification result.
- The updated provider-readiness or compliance record.
- The updated blocker table.
- The exact commit hash and deployment identifier.
- Any operator approval record, without secrets or unnecessary personal data.

A workstream is not complete because code exists. It is complete only when its exit criteria are verified in the target production environment.

References